

1. Zero Trust Architecture (ZTA)

In my project, Zero Trust was applied using two layers of enforced access control:

- **Identity and Access Management (IAM):** All users were authenticated using multi-factor authentication (MFA) before gaining access to the system. Each user was assigned **role-based permissions**, ensuring least privilege access.
- **Network Segmentation with Microsegmentation:** Even after authentication, traffic between services was controlled through software-defined microsegmentation. For example, a user with database read access could not directly communicate with the application server without going through the API gateway.

This demonstrated the Zero Trust principle of “never trust, always verify” across **user and network layers**.

2. Defense in Depth (DiD)

I designed a system architecture that incorporated **three layers of defense**:

1. **Perimeter Security (Firewall + IDS/IPS):** A next-gen firewall monitored traffic, blocking unauthorized access and using intrusion detection/prevention to identify suspicious activity.
2. **Endpoint Protection:** Workstations and servers used antivirus, host-based intrusion detection (HIDS), and device encryption. This ensured that even if the perimeter was bypassed, endpoints remained protected.
3. **Application Security Controls:** Input validation, secure coding practices, and a Web Application Firewall (WAF) were implemented to prevent injection attacks and cross-site scripting at the application layer.

By layering defenses, attackers would have to overcome multiple barriers, reducing the likelihood of a full compromise.

3. Supply Chain Security

During the project, one **supply chain risk** was identified: reliance on **third-party open-source software libraries**. An outdated library had a known vulnerability (example: Log4j).

- **Mitigation:** A software composition analysis (SCA) tool was used to scan dependencies. Vulnerable packages were patched or replaced with secure versions. Additionally, all future dependencies were pulled only from trusted, verified repositories.

This showed proactive supply chain risk management by addressing third-party software vulnerabilities.

4. Advanced Security Model – Bell-LaPadula

I applied the **Bell-LaPadula (BLP) model** to enforce confidentiality in a simulated environment:

- **Scenario:** A system storing classified documents at multiple levels (Public, Confidential, Secret).
- **Implementation:**
 - Users were assigned clearance levels.
 - Files were labeled with classification levels.
 - The **Simple Security Property** (no read up) ensured a Confidential user could not access Secret files.
 - The **Star Property** (no write down) prevented a Secret-cleared user from writing to Public files, avoiding data leaks.

This model was appropriate because confidentiality was the highest priority in the system, ensuring sensitive data did not leak to lower-level users.

1. Incident Response Plan (IRP)

My project included a structured **5-step Incident Response Plan**:

1. **Preparation:**

- Security policies were established and staff trained on reporting suspicious activity.
- Logging and monitoring were configured on servers and endpoints.

2. Identification:

- Alerts from the IDS/IPS and system logs were monitored.
- An unusual spike in failed login attempts was detected on the web server, indicating a possible brute force attack.

3. Containment:

- The compromised account was locked.
- The attacker's IP address was blocked at the firewall.

4. Eradication:

- Malicious files identified by antivirus were removed.
- Patches were applied to address the exploited vulnerability.

5. Recovery:

- The affected system was restored from a clean backup.
- Normal operations resumed after verifying integrity and stability.

2. Digital Forensics Basics

To support investigation, I used the **Volatility tool** (memory forensics) to capture and analyze running processes. This allowed me to:

- Identify suspicious processes running in memory.
- Extract network connections active during the attack.

Alternatively (depending on your environment), you could also use **Autopsy** or **FTK Imager** for file system evidence collection.

3. Evidence Collection & Chain of Custody

Two forms of evidence were collected:

- **Log files:** Authentication logs showing repeated failed login attempts from the attacker's IP.
- **Screenshots:** Captured evidence of the IDS alert dashboard indicating brute force activity.

Chain of Custody Documentation Example:

Case ID: IR-2025-001

Collected By: Matthew Rich

Date/Time: 10/03/2025 14:30 EST

Evidence Item #1: auth.log (server authentication log)

Evidence Item #2: IDS alert screenshot

Transferred To: Incident Response Lead

Date/Time: 10/03/2025 15:00 EST

Integrity Verified: Yes (hash values recorded)

4. Incident Triage & Prioritization

Incidents were categorized by **severity and business impact**:

1. **Low Severity:** Phishing email detected but no link clicked → minimal business impact, isolated quickly.
 2. **Medium Severity:** Malware detected on one workstation → moderate disruption, but contained before spreading.
 3. **High Severity:** Brute force attack on production server leading to potential data compromise → critical system, required immediate response.
-

5. Post-Incident Analysis

Incident Outcome: The brute force attack was successfully contained before any unauthorized data access occurred. The affected account was secured, and the attacker's access was blocked.

Lessons Learned:

1. **Need for Stronger Authentication Controls:** Implement multi-factor authentication (MFA) to reduce risk of brute force success.
2. **Improved Monitoring:** Automate alerts for excessive failed login attempts to speed up detection and response.

1. SOC Functions & Operations

A Security Operations Center (SOC) provides centralized monitoring, detection, and response to security incidents. In my project, I identified **three primary SOC roles**:

- **Tier 1 Analyst (Alert Triage):** Monitors dashboards, reviews alerts, and escalates incidents that require deeper investigation.
 - **Tier 2 Analyst (Incident Investigator):** Conducts forensic analysis, validates whether alerts are real threats, and recommends containment steps.
 - **SOC Manager:** Oversees SOC operations, manages escalation procedures, ensures compliance with organizational policies, and coordinates with executives.
-

2. Monitoring Fundamentals

For monitoring, I configured **Wazuh SIEM** (open-source SOC tool). Two types of network activity monitored were:

1. **Authentication Logs:** Monitoring login attempts across endpoints and servers.
Example: failed SSH logins recorded in `/var/log/auth.log`.
2. **Network Traffic Activity:** Monitoring inbound and outbound connections through Wazuh's integration with Suricata (IDS), detecting port scans and abnormal traffic spikes.

This demonstrated how a SOC continuously monitors for both **user activity** and **network anomalies**.

3. Alert Management

During the project, two alerts were generated and resolved:

- **Alert 1 – Brute Force Login Attempt:**
 - **Generated:** Multiple failed SSH login attempts triggered an alert.
 - **Investigated:** Analyst reviewed logs confirming repetitive attempts from the same IP.
 - **Resolved:** IP was blocked via firewall rules, and MFA was enforced for accounts.
 - **Alert 2 – Suspicious Outbound Traffic:**
 - **Generated:** IDS detected abnormal outbound connections to an unfamiliar IP.
 - **Investigated:** Analyst correlated traffic with process logs, finding malware attempting to beacon out.
 - **Resolved:** Infected workstation isolated, malware removed, and threat intelligence feeds updated.
-

4. Basic Threat Detection

Identified Threat: Malware infection on a workstation.

- **Detection:** SOC tools flagged abnormal outbound connections (Command & Control beaconing). Logs showed processes making repeated HTTP requests to a blacklisted domain.
- **Response:** The SOC team isolated the machine, eradicated the malware, and blocked the malicious domain in the firewall and DNS filter.

This showed how SOC tools and workflows enable real-time **threat detection and containment**.

1. Security Policy Document

A. Access Control Policy

- All user accounts must follow **least privilege principles**.
- Multi-factor authentication (MFA) required for remote access.
- Accounts reviewed quarterly for unused or excessive permissions.
- Administrative access logged and monitored via SIEM.

B. Data Protection Policy

- Sensitive data must be encrypted at rest (AES-256) and in transit (TLS 1.2+).
- Backups performed daily and tested monthly for integrity.
- Data classification labels (Public, Internal, Confidential, Restricted) applied to all organizational data.
- Data retention schedules established, with secure disposal procedures for obsolete data.

C. System Use Policy

- Corporate systems must be used strictly for authorized business purposes.
- Installation of unauthorized software prohibited.
- Employees prohibited from bypassing security controls (firewalls, AV, endpoint protection).
- Internet usage monitored to prevent access to malicious or inappropriate sites.

2. Governance Structure

Roles & Responsibilities:

- **CISO (Chief Information Security Officer):** Oversees policy creation, ensures compliance with external regulations, and reports to executive leadership.
 - **IT Security Manager:** Implements technical controls (firewalls, SIEM, IAM), monitors enforcement, and coordinates with SOC.
 - **Department Heads:** Ensure employees follow policies within their teams, report violations.
 - **All Employees:** Responsible for understanding and adhering to system use, data handling, and access rules.
-

3. Compliance Requirements

The policy framework aligns with **ISO 27001** and **NIST Cybersecurity Framework (CSF)** principles:

- **ISO 27001 A.9 – Access Control:** Ensures appropriate user rights and authentication.
 - **NIST CSF PR.DS – Data Security:** Requires protection of information at rest and in transit.
 - **ISO 27001 A.13 – Communications Security:** Addresses secure use of systems and networks.
-

4. Policy Implementation

Evidence of Communication & Enforcement:

- Policies were distributed via the company intranet and acknowledged by employees through mandatory training sessions.
- Access control enforcement was demonstrated by configuring **role-based access in Active Directory**, requiring MFA for all remote connections.
- Data protection policy enforced by enabling **disk encryption on endpoints** and **TLS on web servers**.

- System use monitored through SIEM dashboards, which generated alerts when unauthorized applications were executed.

1. Cybersecurity Procedure Document

Title: Firewall Configuration and Monitoring Procedure

Purpose: To ensure only authorized traffic is allowed into the corporate network and to detect malicious attempts.

Scope: Applies to all perimeter firewalls protecting the organization's network.

Procedure:

1. Access firewall management console.
2. Apply inbound/outbound rules according to access control policy (deny by default, allow by exception).
3. Enable logging for all denied connections.
4. Forward logs to centralized SIEM for monitoring.
5. Review firewall rules monthly to ensure compliance.

2. Step-by-Step Guide (Process Documentation)

Patch Management Procedure

1. **Identify:** Weekly check for new patches from vendor advisories.
2. **Evaluate:** Test patches in staging environment for compatibility.
3. **Approve:** Security team approves critical patches within 48 hours of release.
4. **Deploy:** Apply patches automatically via centralized update server (e.g., WSUS for Windows, apt/yum repos for Linux).
5. **Verify:** Confirm successful patching with vulnerability scans.
6. **Document:** Update patch management log with patch ID, date, and system applied.

3. Security Playbooks

Playbook A: Phishing Email Incident

- Step 1: User reports suspicious email to SOC.
- Step 2: SOC Tier 1 analyst collects email headers and attachment hashes.
- Step 3: Tier 2 analyst checks against threat intelligence feeds.
- Step 4: If malicious, block sender domain/IP at email gateway.
- Step 5: Notify affected users, update awareness training database.

Playbook B: Malware Detection on Endpoint

- Step 1: Alert triggered by endpoint security tool.
- Step 2: SOC isolates infected device from network.
- Step 3: Collect forensic image of disk/memory.
- Step 4: Eradicate malware (re-image or AV clean).
- Step 5: Restore from known clean backup.
- Step 6: Document incident in IR tracking system.

4. Knowledge Base Management

Structured Repository (example categories + resources):

- **Policies & Standards**
 - Access Control Policy v1.2
 - Data Protection Standard (aligned with ISO 27001)

- **Procedures & Playbooks**

- Patch Management Procedure (above)
- Phishing and Malware Incident Response Playbooks

- **Reference Resources**

- NIST Cybersecurity Framework (NIST CSF) reference PDF
 - Vendor Security Advisory Portal (Microsoft, Ubuntu, etc.)
 - Internal Training Guide: Secure System Use
-